Handout S08: Mô phỏng Tấn công & Phòng thủ Hạ tầng PKI (AD CS, Rogue CA, MitM)

Học phần: Cơ sở hạ tầng khóa công khai (ATHK 512) · Lớp CHAT4P
Đơn vị: Khoa An toàn Thông tin — Phân hiệu Học viện Kỹ thuật Mật mã tại TP.HCM
Giảng viên: Nguyễn An Khương (Khoa Khoa học & Kỹ thuật Máy tính, Trường ĐHBK Tp. HCM · ORCID: 0000-0002-9910-6387)
Trợ giảng: Nguyễn Hữu Hoàng Huy

---

1. Bề mặt Tấn công Khai thác Lỗ hổng Cấu hình Mẫu Chứng thư (AD CS ESC1)

Trong môi trường Active Directory Certificate Services (AD CS), cấu hình sai mẫu chứng thư (Certificate Template) là con đường ngắn nhất để kẻ tấn công chiếm toàn quyền kiểm soát miền (Domain Admin):

```
sequenceDiagram
    autonumber
    actor Attacker as Kẻ tấn công (Tài khoản User cấp thấp)
    participant CA as Active Directory CS (CA)
    participant DC as Domain Controller (KDC Kerberos)

    Note over Attacker: Phát hiện Template có cờ:<br/>ENROLLEE_SUPPLIES_SUBJECT (CT_FLAG_ENROLLEE
    Attacker->>CA: Gửi yêu cầu xin cấp chứng chỉ cho chính mình<br/>nhưng chèn SAN: administrator
    Note over CA: Không kiểm duyệt đặc quyền!<br/>Phát hành chứng chỉ mạo danh Domain Admin
    CA-->>Attacker: Trả về chứng chỉ Administrator.pfx
    Attacker->>DC: Bắt tay Kerberos PKINIT sử dụng chứng chỉ mạo danh
    DC-->>Attacker: Trả về Kerberos TGT (Ticket Granting Ticket) của Domain Admin
    Note over Attacker: Toàn bộ Active Directory Domain bị chiếm quyền hoàn toàn!
```

---

2. Kỹ thuật Tấn công Tiếp sóng NTLM Relay vào Web Enrollment (ESC8)

Kẻ tấn công ép buộc máy chủ Domain Controller xác thực ngược lại máy mình thông qua giao thức RPC (PetitPotam / MS-EFSRPC), sau đó chuyển tiếp (relay) bản tin xác thực NTLM tới dịch vụ AD CS Web Enrollment (chưa bật HTTPS hoặc thiếu Extended Protection for Authentication - EPA) để lấy chứng chỉ quản trị máy tính:

```
flowchart LR
    Attacker["Kẻ tấn công<br/>(ntlmrelayx)"]
    Victim["Domain Controller<br/>(Nạn nhân)"]
    ADCS["AD CS Web Enrollment<br/>(http://ca/certsrv)"]

    Attacker -->|1. Kích hoạt PetitPotam| Victim
    Victim -->|2. Gửi gói tin NTLM Auth| Attacker
    Attacker -->|3. Tiếp sóng NTLM Relay| ADCS
    ADCS -->|4. Cấp chứng chỉ DC.pfx| Attacker
    Attacker -->|5. Chiếm quyền Domain| Victim
```

---

3. Kiến trúc Phòng thủ Đa tầng (Defense in Depth for PKI)

```
graph TD
    Defense["PHÒNG THỦ HẠ TẦNG PKI ĐA TẦNG"]

    Defense --> Layer1["1. Củng cố Mẫu Chứng thư (Hardening)<br/>- Bỏ cờ Enrollee Supplies Subjec

    Defense --> Layer2["2. An toàn Giao thức Xác thực<br/>- Vô hiệu hóa NTLM toàn mạng<br/>- Kích

    Defense --> Layer3["3. Giám sát Liên tục (Observability)<br/>- Kiểm tra CT Logs định kỳ phát
```

---

4. Tài liệu Tham khảo Chuẩn Quốc tế

1. **Will Schroeder & Lee Christensen:** *Certified Pre-Owned: Abusing Active Directory Certificate Services*, SpecterOps Whitepaper, 2021.
2. **CISA Alert AA22-321A:** *Stop Ransomware: Misconfigured Active Directory Certificate Services*, Cybersecurity and Infrastructure Security Agency, 2022.
3. **MITRE ATT&CK:** *Technique T1649: Steal or Forge Authentication Certificates*. attack.mitre.org/techniques/T16